Executive Summary: Cybersecurity Risk Assessment

Apex Financial Partners (Fictional Firm)

Miles Brandon

Overview

Apex Financial Partners' most serious cybersecurity risks come from basic gaps in email security, backups, and login protection, not from advanced attacks. Acting on the five risks below addresses the largest exposures.

This assessment covers 15 assets at a fictional 30-person financial advisory firm that manages client investment accounts and tax records. Each asset was paired with a threat and a firm-specific weakness, then scored for likelihood and impact on a 1-5 scale. The result: 2 Critical, 8 High, and 5 Medium risks, and none rated Low.

Many of the highest risks trace back to two weaknesses: access controls (no multi-factor authentication, shared logins, accounts not removed when staff leave) and recovery readiness (backups that are never tested).

Top five risks

The five highest-scoring risks (score = likelihood x impact, out of 25) are below.

#	Risk	Score	Why it matters	Recommended action
1	Email compromise	20 (Critical)	Advisors send sensitive documents by email and receive no phishing training. A hijacked mailbox could expose client data or be used for fraudulent requests.	Add email protections and regular phishing training
2	Ransomware on the shared drive and backups	20 (Critical)	Backups are never tested or restored. An attack could halt work and leave the firm unable to recover client records.	Keep offline backups and test restores on a schedule
3	Client portal account takeover	16 (High)	Clients log in with only a password. Stolen credentials would give an attacker direct access to client accounts.	Require multi-factor authentication

#	Risk	Score	Why it matters	Recommended action
4	Breach of client personal and financial data	15 (High)	Data is stored in several places with no clear limits on who can access it.	Encrypt the data and limit access
5	Fraud through corporate cards and banking credentials	15 (High)	Credentials are saved in browsers or shared by email, so one compromised account could move money.	Require dual approval and stop saving logins

What to fix first

Start with backups and multi-factor authentication, because they address the highest-impact risk and several others at once. The recommended order:

1. **Make backups recoverable.** Keep an offline copy and run a test restore on a schedule. Ransomware on the shared drive carries the highest possible impact score (5), and a tested backup limits the damage.
2. **Turn on multi-factor authentication everywhere it is missing:** the client portal, email, the domain registrar, and banking accounts. One control reduces several risks in this register, including portal takeover and domain hijacking.
3. **Protect email and train staff.** Add email protections and run phishing training, since email is the most likely way in.
4. **Limit and encrypt client data.** Find where it is stored, restrict who can open it, and encrypt laptops and phones.
5. **Lock down payment credentials.** Require a second person to approve payments and stop saving logins in browsers or sharing them by email.

The other ten risks

The remaining ten risks (5 High and 5 Medium) are scored and tracked in the full risk register, each with a recommended safeguard. They include payroll and HR systems, advisor laptops, the VPN gateway, API keys, the CRM and billing software, USB drives, the domain name, multi-factor authentication tokens, keycards, and paper records. Several overlap with the five fixes above, so work on the top five will also reduce some of them.

Scope and limits

This is a portfolio project for a fictional firm, so the scores are my own judgments, not measurements. No systems were tested or scanned, and the firm and its weaknesses were invented for the exercise. Risks were scored qualitatively on a 1-5 scale and organized

with NIST CSF 2.0; recommended safeguards cite CIS Controls v8 where it applies, with process and physical controls labeled separately. The ranking is based on score and breadth, and it does not include cost or staffing estimates, which a real engagement would add before setting priorities.

The full risk register (Excel and PDF) is in the GRC portfolio on GitHub: github.com/mlbrandon/grc-portfolio.